

Audit technique — Site M'GYM

Phase 1 : état des lieux avant intégration d'un back-office Sanity

Projet	M'GYM — Bien-être & Santé, Mirepoix-sur-Tarn
Dépôt	AntonFrDe/Mgym-WebSite — branche REFONTE-3
Date	21 août 2026
Statut	Audit terminé — aucun fichier modifié, aucun commit produit
Objet	Rendre le contenu du site administrable par une personne non technique, sans modifier le design ni les animations

Synthèse

Le dépôt contient une **refonte Next.js jamais déployée**. Le site réellement en ligne sur `mgym.fr` est un site distinct, construit avec Hostinger Website Builder, qui dispose déjà d'un éditeur visuel. Ce constat déplace l'argumentaire du projet : la cliente peut déjà éditer son site. Ce que le CMS apporte, c'est de l'éditer **sans pouvoir casser le design**, plus un planning structuré et un SEO maîtrisé.

Trois points bloquent le démarrage de la Phase 2 : le devenir du site Hostinger, le sort du pipeline de livraison hors-ligne, et une mise à jour de sécurité préalable. Ils sont détaillés en fin de document.

Constat	Gravité	Conséquence
<code>mgym.fr</code> est déjà en ligne, sur une autre pile, avec un back-office	Structurant	Redéfinit la valeur du projet
<code>output: 'export'</code> incompatible avec la prévisualisation	Bloquant	Vérifié par expérience — arbitrage requis
4 vulnérabilités <i>high</i> dans les dépendances	Élevée	À corriger avant tout ajout
<code>key={act.name}</code> dans les deux affichages d'activités	Élevée	Réintroduit un bug d'animation connu
Aucun secret dans l'historique git	Sain	Rien à assainir
<code>.gitignore</code> ne couvre pas <code>.env</code>	Moyenne	À corriger avant Sanity

1. Inventaire technique

Point	Réalité constatée
Framework	Next.js 15.5.19 , App Router — ni Vite, ni SPA
React	18.3.1 / react-dom 18.3.1
Node	v18.19.1
TypeScript	Absent. Aucun tsconfig.json, aucun .ts/.tsx hors généré
Mode de rendu	output: 'export' — export statique intégral vers out/
Routing	Une seule route (app/page.js). Navigation par ancrs uniquement
Gestion d'état	useState/useRef locaux. Pas de Context, pas de store
Animations	Maison, sans dépendance : IntersectionObserver, transitions CSS, SVG stroke-dashoffset
Styles	Un seul fichier, app/globals.css (944 lignes). Ni Tailwind, ni CSS Modules
Dépendances	3 exactement : next, react, react-dom
Hébergement	Aucun configuré. Ni Vercel, ni Netlify, ni CI, ni Docker
Livraison actuelle	Fichier HTML autonome déposé sur Google Drive
Serveur local	serve.js, 93 lignes sur le module http de Node

Volumétrie : 21 fichiers source, environ 2 400 lignes hors CSS. Composants clients : Nav.js, ClientLayout.js, SentierActivites.js, CarouselActivites.js. Tous les autres sont des composants serveur.

Deux variantes coexistent, choisies par la variable MGYM_VARIANT : CarouselActivites (défaut) et SentierActivites. Les deux consomment le même activitesData.js. Toute intégration CMS doit alimenter les deux.

2. Cartographie du contenu en dur

Chaque ligne a été relevée dans le code réel, avec ses numéros de ligne.

Fichier	Lignes	Contenu	Éditable
app/layout.js	26-29	Titre + description SEO	OUI → siteContent
Hero.js	4	5 pastilles d'activités du bandeau	OUI
Hero.js	15-19	Titre « Bougeons / ensemble »	OUI → heroTitre
Hero.js	25-26	Libellés des 2 boutons + ancres	Libellés OUI / ancres NON
globals.css	145	Image de fond du hero	OUI → heroImage (en CSS)
Manifesto.js	9-12	Citation du bandeau sombre	OUI → citationBandeau
About.js	25-30	Étiquette + titre de section	OUI
About.js	31-39	Paragraphe « Notre histoire »	OUI → aProposTexte
About.js	44-49	5 puces « Rejoindre M'GYM »	OUI
About.js	55-62	Conclusion + mots en accent	OUI (Portable Text)
About.js	20, 22-24	Photo + badge « +40 ans »	OUI
activitesData.js	25-85	Les 8 activités (nom, image, accroche, description, tags, lien)	OUI → activite
EnteteActivites.js	18-24	Titre + chapô section Activités	OUI
Outdoor.js	14-22, 40-52	7 étiquettes + titre + paragraphe	OUI
Bespoke.js	8, 32-42	4 publics + titre + paragraphe	OUI
Coach.js	8-14, 31-58	5 certifications, 3 statistiques, paragraphe	OUI
Pricing.js	18-62	Adhésion, 3 formules, tarifs saison et partiels	OUI
Pricing.js	76-88	7 items « Il vous sera demandé »	OUI — miroir du Google

			Form
Planning.js	14-16	Jours affichés + libellé de saison	OUI
Planning.js	22-54	Les créneaux , groupés Matin / Midi / Soir	OUI → creneau
Planning.js	62, 74-77	Stages (vide) + chapô	OUI → evenement
Contact.js	5-34, 61-67, 80-84	3 cartes, titre CTA, ligne d'aide	OUI → infosPratiques
Reseaux.js	17-30	Facebook — URL générique non renseignée	OUI → reseauxSociaux
Footer.js	9-17	7 liens de navigation	NON (structure)
Footer.js	35-38, 69-71	Slogan + mentions légales	OUI
liens.js	8-10, 23-36	Téléphone, courriel, URLs de formulaires	OUI → infosPratiques

Marqué NON — relève du design, ne doit jamais remonter dans le CMS

globals.css en entier, hors la ligne 145 · l'ordre des sections dans app/page.js (28-46) · l'alternance des fonds crème / rose · les classes .apparition* et .retard-* · buildPath() dans SentierActivites.js (18-30) · toute la mécanique du carrousel · les SVG inline · build-standalone.js.

3. Point de vigilance : le scrolltelling

3.1 La contrainte documentée

Dans `SentierActivites.js`, lignes 78 à 107, chaque étape porte **deux états séparés** :

```
estOuvert    <- le clic sur « En savoir plus »  
  
estVisible   <- l'IntersectionObserver au défilement
```

Le commentaire du code est explicite : « *jamais remis à false : le clic ne touche jamais ce state* ». Le bug historique venait d'un accordéon où le clic réinitialisait la classe posée par l'observateur, faisant disparaître l'étape.

Un troisième mécanisme opère en parallèle : `useTraceAuScroll` (lignes 34-73) mesure `path.getTotalLength()` **une seule fois au montage** et pilote `strokeDashoffset` au défilement.

3.2 Les trois ruptures introduites par le passage en dynamique

Ce ne sont pas des hypothèses : elles découlent directement du code lu.

#	Rupture	Mécanisme et mitigation
1	<code>key={act.name}</code> <i>SentierActivites.js:195</i> <i>CarrouselActivites.js:151</i>	Le titre sert de clé React. Dès qu'une faute est corrigée dans Sanity, React voit une clé différente, démonte l'étape et la remonte avec <code>estVisible = false</code> : l'étape disparaît jusqu'à ce que l'observateur la revoie — or l'utilisateur a déjà défilé. Mitigation : clé = <code>_id</code> Sanity, stable à la renomination. Non négociable.
2	<code>const SENTIER = buildPath(activities.length)</code> <i>portée module, ligne 32</i>	Le tracé SVG est calculé à l'import, sur un tableau statique. Avec des données dynamiques, le nombre d'activités devient variable. Mitigation : déplacer le calcul dans le composant, mémorisé sur la longueur du tableau.
3	<code>useTraceAuScroll</code> <i>dépendances [pathRef, wrapRef]</i>	Des refs, donc stables : l'effet ne s'exécute qu'une fois. Si le <code>d</code> du chemin change après le montage, le <code>strokeDasharray</code> reste calculé sur l'ancienne longueur. Mitigation : ajouter la longueur du chemin aux dépendances.

La décision qui neutralise les trois d'un coup

Récupérer les données de Sanity **au moment du build**, pas dans le navigateur. En génération statique, les composants reçoivent leur tableau d'activités complet au premier rendu : la rupture 1 reste à corriger, mais les ruptures 2 et 3 ne peuvent plus se produire, puisque rien ne change après le montage. C'est le mode de rendu qui protège l'animation, pas du code défensif.

Un rendu côté client casserait aussi le filet de sécurité : le site Next **n'a pas** le `setTimeout` de 3 secondes qui existe

dans `build-standalone.js` (lignes 99-102). Une étape montée après que l'utilisateur l'a dépassée resterait invisible indéfiniment.

4. Le site actuellement en ligne

Vérification DNS et HTTP effectuée le 21 août 2026 :

mgym.fr HTTP 200 server: hcdn x-powered-by: HostingerWebsiteBuilder

www.mgym.fr HTTP 200

admin.mgym.fr aucun enregistrement DNS

Domaine déposé le 29/06/2022, expire le 29/06/2027, modifié le 31/07/2026

Le site public actuel n'est pas ce dépôt. C'est un site construit avec **Hostinger Website Builder** (317 Ko, moteur Astro interne à Hostinger). Il contient « Bougeons », « M'GYM », « Mirepoix », « Emmanuelle », et dispose déjà d'une page blog (/blog-list, actuellement sans article).

La cliente dispose déjà d'un back-office. Hostinger Website Builder est un éditeur visuel WYSIWYG : elle peut aujourd'hui modifier n'importe quel texte, n'importe quelle image, et publier, sans développeur. La mission telle qu'énoncée décrit donc un problème qui, sur mgym.fr, est déjà résolu.

Le projet garde tout son sens, mais son argumentaire doit être reformulé. Ce que Sanity apporte réellement :

	Hostinger Builder (actuel)	Next + Sanity (cible)
Autonomie de la cliente	Totale	Sur le contenu modélisé
Peut casser le design	Oui, facilement	Impossible par construction
Planning récurrent + exceptions	Ressaisie manuelle	Modèle métier
Données structurées Schema.org	Non	Oui
Le design de la refonte	Non	Oui
Historique et restauration	Limité	Complet
Coût	Inclus dans l'abonnement	Free tier + hébergement

Le gain réel n'est pas « elle pourra éditer » — elle le peut déjà. C'est « **elle pourra éditer sans pouvoir casser** », plus le planning structuré et le SEO.

5. Stratégie de rendu : production contre prévisualisation

5.1 Le conflit, tranché par l'expérience

Le cahier des charges accepte une production statique et une prévisualisation dynamique, et rend la prévisualisation obligatoire. Or `next.config.js` contient `output: 'export'`.

Le conflit n'a pas été supposé mais **testé** : copie jetable du projet, ajout d'une route `/api/preview` utilisant `draftMode()`, puis `build`.

```
Error: export const dynamic = "force-static" not configured on route

    "/api/preview" with "output: export"

> Build error occurred
```

`output: 'export'` et la prévisualisation sécurisée sont **mutuellement exclusifs dans une même configuration**. C'est définitif.

5.2 Ce que cela n'implique pas

`output: 'export'` n'est pas synonyme de « site statique ». Next hébergé sur un runtime Node génère tout de même **l'intégralité du HTML au build** et le sert depuis un CDN. Le référencement et les performances sont identiques. Le drapeau `export` ne sert qu'à produire un dossier `out/` portable.

5.3 Architecture recommandée

```
next.config.js -> retirer output: 'export' du build par défaut

Hébergement    -> Vercel / Netlify / Cloudflare Pages (runtime Node)

Production     -> génération statique, contenu publié uniquement, servi par CDN

Preview        -> draftMode() + route validant un secret, no-store, noindex

Publication    -> Sanity publish -> Deploy Hook de l'hébergeur
```

Le Deploy Hook présente un avantage de sécurité décisif : **aucune API publique à écrire**, donc aucune signature à vérifier, aucune limitation de débit à implémenter. La surface d'attaque disparaît par construction plutôt que par mitigation.

5.4 La contrepartie : le pipeline de livraison hors-ligne

`build-standalone.js` (344 lignes), `serve.js` (93 lignes) et le dossier `Livraison-MGYM/` dépendent de `out/`. Ils existaient pour montrer le site à la cliente avant mise en ligne, par courriel ou Google Drive — c'est précisément ce

que la prévisualisation Sanity remplace, en mieux.

Option	Décision	Conséquence
1	Retirer le pipeline (environ 450 lignes)	Sa fonction est reprise par la preview. Perte : plus de copie hors-ligne
2	Le conserver via un second mode de build	La route de preview devrait être exclue de ce build — non supporté nativement par Next
3	Le réécrire pour aspirer le site déployé	Recommandée. Préserve la fonctionnalité, supprime le couplage à output : 'export ', simplifie le script

6. Dépendances

21 paquets installés · 475 Mo · package-lock.json commité (OK)

npm audit : 4 vulnérabilités HIGH, 0 critique

Paquet	Problème	Correctif
next 15.5.19	5 CVE : déni de service sur Server Actions, SSRF, confusion de cache	next@15.5.23
postcss	4 CVE : XSS via </style>, traversée de chemin par sourceMappingURL	transitif Next
nanoid	2 CVE : boucle infinie sur taille nulle ou négative	transitif
sharp < 0.35	4 CVE héritées de libvips	transitif

Les quatre sont **transitives à Next**. La commande `npm audit fix --force` installe next@15.5.23, correctif de patch sans rupture d'API attendue.

À traiter avant d'ajouter quoi que ce soit. Installer Sanity par-dessus une base vulnérable revient à empiler la dette de sécurité.

7. Sécurité de l'existant

Point	État	Détail
Secrets dans l'historique git	Sain	8 021 lignes de diff analysées sur les sources versionnées, hors binaires et bundles
Fichier .env commité	Sain	Aucun, sur toutes les branches
.env.local présent	Sain	Contient KOKO_PRO_TOKEN, correctement ignoré par git
.gitignore	À corriger	Ne couvre que .env*.local : .env et .env.production passeraient
.env.example	Absent	À créer
En-têtes de sécurité	Absents	Le site n'est pas hébergé. Hostinger en pose sur mgym.fr, hors de notre contrôle

dangerouslySetInnerHTML	Sain	Aucune occurrence dans le code
CORS Sanity	—	Projet Sanity inexistant à ce jour

8. Ce que le cahier des charges résout

Section	Arbitrage rendu
§11	JavaScript + JSDoc + types Sanity générés. Pas de migration TypeScript. Cohérent avec la documentation existante du projet
§12	« Aucune dépendance inutile » et non « exactement 3 ». Le conflit avec CLAUDE.md disparaît ; cette ligne de la documentation devra être amendée
§4	Le rendu Matin / Midi / Soir est conservé. Le modèle creneau / exception / fermeture vit derrière et se regroupe à l'affichage. Faisable sans toucher au visuel
§5	Confirme les trois ruptures d'animation identifiées en section 3. L'analyse tient sans modification

9. Contradictions résiduelles

1. **La documentation du projet contredit la mission.** CLAUDE.md interdit encore TypeScript et toute dépendance hors des trois socles. À amender en Phase 2, sinon la documentation contredira le code livré.
2. **Le cahier des charges fixe mgym.fr comme site public.** Or ce domaine sert aujourd'hui un autre site, avec un blog déjà en place. Basculer signifie **remplacer le site actuel de la cliente**, pas en publier un nouveau. Ce n'est pas un détail technique mais une décision commerciale.
3. **Le blog existe déjà** sur mgym.fr/blog-list, vide. La mission le traite comme une fonctionnalité neuve.

10. Questions bloquantes

#	Question	Enjeu
1	Le site Next remplace-t-il mgym.fr, ou vit-il ailleurs ?	En cas de remplacement, la cliente perd son éditeur WYSIWYG Hostinger. C'est voulu — c'est ce qui protège le design — mais elle doit l'avoir accepté. Le DNS devra être repointé depuis Hostinger.
2	Le pipeline de livraison hors-ligne : option 1, 2 ou	Recommandation : option 3, réécriture pour aspirer le site déployé.

	3 ?	
3	Passage de next en 15.5.23 avant la Phase 2 ?	Correctif de sécurité, version de patch, à isoler dans son propre commit.

Annexe — méthode de vérification

Toutes les affirmations de ce document reposent sur une observation directe :

- Lecture intégrale des 21 fichiers source, de `globals.css`, des scripts de build et de la documentation du dépôt.
- Relevé des numéros de ligne par recherche automatisée, puis vérification manuelle de chaque plage citée.
- `npm audit` sur l'arbre de dépendances installé.
- Analyse de l'historique git complet, toutes branches, sur les sources versionnées, binaires et bundles générés exclus.
- Résolution DNS et requêtes HTTP sur `mgym.fr`, `www.mgym.fr`, `admin.mgym.fr`, interrogation RDAP de l'AFNIC.
- Test de compatibilité output : `'export'` exécuté dans une copie jetable du projet, supprimée après usage.

Le dépôt a été vérifié intact à l'issue de l'audit : aucun fichier modifié, aucun commit produit.